

IntentGrant

物理意图授权协议规范

Physical Intent Authorization Protocol Specification

项目	内容
规范名称	IntentGrant 物理意图授权协议规范
版本	v2.0（中立化版本 / Neutral Release）
发布日期	2026-09-06
协议设计方	苏亚伟（Su Yawei）
文档状态	规范草案 — Standards Track（面向社区评议与产业采用）
目标许可证	Apache License 2.0（规范文本与参考实现）
关键词	任务级授权、物理确认、AI Agent、可审计、OAuth RAR、端点绑定
适用范围	AI Agent 发起的高后果操作（High-Consequence Action）的人类确认与授权

本规范为中立化版本：删除全部厂商与产品品牌标识，仅保留协议设计方署名，以便提交社区评议、产业采用与标准化流程。所有未实现能力均在第 12 章明确标注。

目录

TOC \h \o "1-2"

摘要

本规范定义 IntentGrant——一种面向 AI Agent 执行链路的“任务级物理意图授权”协议层。它解决的核心问题是：当 AI Agent 代替人类发起一次高后果操作（支付、删除、外发、生产变更、交易履约）时，如何以可验证、可审计、不可否认的方式证明——“此刻确实是本人主动想要执行这次操作”。

OAuth 2.0 回答的是“你是谁”（身份认证与委托授权）；IntentGrant 回答的是“此刻是不是你主动想要执行这次操作”（运行时真人意图确权）。二者不是替代关系，而是互补关系：IntentGrant 被设计为运行在 OAuth 2.0 及其细粒度授权扩展之上的一层“人类确认事件”协议。

协议采用四层架构：设备激活层（Layer 0）确保“物理持有 ≠ 权限获得”；物理动作层（Layer 1）把人体动作解析为带风险等级的事件；授权凭证层（Layer 2）签发限时、单次、最小化的授权凭证；审计层（Layer 3）提供不可篡改的链式留痕。

本规范中的所有安全声明均按第 12 章“实现状态声明”分级标注：已实现（原型）、设计意图（依赖量产安全版本）、未来工作。任何超出当前实现范围的能力，均不作为既成事实陈述。

1. 协议定位与问题定义

1.1 问题陈述

AI Agent 正在从“生成内容”走向“执行任务”。当 Agent 获得调用工具、操作界面、发起交易的权限后，一个此前不存在的问题出现了：系统无法区分“用户主动授权的操作”与“Agent 自主发起或误判的操作”。

纯软件方案（弹窗确认、二次密码、短信验证码）在此场景下存在三个结构性缺陷：

- 可委托性漏洞：软件确认运行在被 Agent 影响的同一信任域内，无法防御会话劫持、社工诱导与提示注入。
- 无实时性：异步验证码无法证明“操作发起的那一刻”本人在场且知情。
- 无物理归因：事后审计只能追溯到“某个登录会话”，无法追溯到“某次具体的人体动作”。

1.2 协议定位

IntentGrant 是一层“物理意图授权协议层”，为每次 AI 指令生成与物理人体动作绑定的、限时有效的、可审计追溯的授权凭证。

一句话定义：OAuth 回答“你是谁”，IntentGrant 回答“此刻是不是你主动想要执行这次操作”。

1.3 核心能力

- 实时真人意图确权：授权凭证由人体物理动作触发，与生物特征绑定核验。
- 限时有效：凭证默认 3-10 分钟过期，单次消费后即失效。
- 权限最小化：每次授权精确到操作级别（读 / 导出 / 外发 / 删除）。
- 全链路审计：从物理动作到业务执行的每一跳均可追溯、可归因。

2. 与现有标准的关系

本规范不试图替代 OAuth 2.0，而是在其之上定义缺失的“任务级人类确认层”。主动对齐既有标准，是本规范可被社区与产业接受的前提。

现有标准 / 草案	与本规范的关系
RFC 9396 (OAuth 2.0 Rich Authorization Requests)	本规范的 Permission_Scope / Constraints 字段结构参考其细粒度授权表达 (authorization_details)，用于描述“本次授权允许什么、拒绝什么”。
IETF Secure Intent Protocol (草案)	在意图绑定 (intent binding)、代理身份 (agent identity)、委托控制 (delegation control)、PoP 抗重放等方面对齐；本规范补充其未覆盖的“物理端点确认”部分。
OAuth 2.0 Token Exchange (RFC 8693)	本规范签发的 Grant 凭证可通过 Token Exchange 换取下游服务的具体操作令牌，实现“意图 → 操作”的凭证兑换。
OAuth 2.0 DPoP / mTLS (RFC 9449 / 8705)	本规范的抗重放与设备绑定依赖 PoP 机制；量产由端点安全芯片提供密钥持有证明。
Microsoft Agent Governance / Intent-Based Authorization	其意图生命周期 (DECLARED → APPROVED → EXECUTING → COMPLETED / VIOLATED) 与本规范凭证状态机语义一致，可作互操作参考。

【规范定位】 本规范应被理解为“OAuth RAR Intent Extensions 与 Secure Intent Protocol 在物理端点确认场景下的具体实现规范”，而非与之竞争的自研协议。

3. 协议架构（四层）

IntentGrant 采用四层架构，逐层把“人体动作”转化为“可验证授权凭证”，最终沉淀为“不可篡改审计记录”。

层级	名称	核心职责	关键产出
Layer 0	设备激活层	端点与操作者身份绑定，确保物理持有 ≠ 权限获得	Bind_Status（绑定状态）
Layer 1	物理动作层	把人体动作解析为带风险等级的结构化事件	eventType（事件类型）
Layer 2	授权凭证层	签发限时、单次、最小化的授权凭证	Grant（授权凭证）
Layer 3	审计层	全链路留痕，链式哈希防篡改	Audit Log（审计日志）

4. Layer 0：设备激活层

4.1 设计原则

硬件本身不等于钥匙，而是“钥匙胚”。 物理持有 ≠ 权限获得。未经身份绑定的端点，任何物理按压均不生成有效签名凭证。

4.2 激活流程

- 端点首次配对时，必须绑定操作者的生物特征（指纹 / 人脸）或独立 PIN 码。
- 激活状态由控制端 App 维护，端点侧存储绑定身份的哈希值。
- 每次建立授权通道前，控制端校验当前操作者与绑定身份是否匹配。
- 未通过身份核验时，端点按压不生成有效签名凭证。

4.3 绑定字段定义

字段	类型	说明
Bind_Type	uint8	0x01 = 生物特征 / 0x02 = PIN 码 / 0x03 = 双因素（生物 + PIN）
Bind_Hash	char[64]	绑定身份的 SHA-256 哈希值
Bind_Status	uint8	0x00 = 未绑定 / 0x01 = 已激活 / 0x02 = 已冻结 / 0x03 = 已锁定
Bind_Timestamp	uint32	绑定时间戳（Unix 时间）
Fail_Count	uint8	连续核验失败次数（≥ 3 自动锁定）
Lock_Until	uint32	锁定截止时间戳（锁定后 30 分钟）

4.4 安全策略

场景	行为
连续 3 次身份核验失败	端点自动锁定 30 分钟，Bind_Status → 0x03
操作者 App 一键挂失	后台收到指令，Bind_Status → 0x02，冻结签名权限
异常行为检测（失联后异地请求）	自动冻结，Bind_Status → 0x02，等待管理员复核
管理员强制解绑	Bind_Status → 0x00，需重新走绑定流程
端点回收 / 转交	旧绑定清除 → 新操作者重新绑定，上下文容器权限迁移

4.5 凭证生成前置校验

```
function tryGenerateGrant(physical_event):
    if device.Bind_Status != ACTIVATED:
        log("端点未激活或已冻结", device.Device_ID)
        return REJECT

    if device.Fail_Count >= 3:
        if now() < device.Lock_Until:
            log("端点已锁定", device.Device_ID, device.Lock_Until)
            return REJECT
        else:
            device.Fail_Count = 0           // 锁定期满重置

    if not verifyUserIdentity(device.Bind_Hash):
        device.Fail_Count += 1
        log("身份核验失败", device.Device_ID, device.Fail_Count)
        if device.Fail_Count >= 3:
            device.Bind_Status = LOCKED
            device.Lock_Until = now() + 30min
        return REJECT

    device.Fail_Count = 0
    return proceedToLayer1(physical_event)
```

【设计意图】Layer 0 的生物特征绑定、锁定与冻结策略，依赖量产安全版本提供的安全存储与可信执行环境。原型阶段以软件模拟方式验证流程逻辑，不具备硬件级抗攻击能力。详见第 12 章。

5. Layer 1：物理动作层

5.1 BLE 广播信息

项	值
Device Name	IG-Button-01（IntentGrant 物理端点参考命名）
Service UUID	0000FF00-0000-1000-8000-00805F9B34FB

5.2 GATT 定义

项	值
Service UUID	0000FF00-0000-1000-8000-00805F9B34FB
Characteristic UUID	0000FF01-0000-1000-8000-00805F9B34FB
Property	Notify

5.3 事件包协议（6 字节）

Byte	字段	说明
0	protocolVersion	协议版本，v2.0 = 0x02
1	deviceType	0x01 = Button（物理按键型端点）
2	eventType	事件类型，见 5.4
3	sequence	0-255 循环递增
4	batteryPercent	电池电量（原型阶段固定 0x5A = 90%）
5	reserved	固定 0x00

5.4 eventType 定义

值	事件	IntentGrant 语义	触发风险等级
0x01	press_down	按下开始	—
0x02	press_up	释放结束	—
0x03	single_click	Stop / Cancel	—
0x04	double_click	Start Listening / 发起意图	Low
0x05	long_press_start	Yes / Continue / Execute	High
0x06	long_press_end	执行确认结束	—
0x07	triple_click	Priority / Emergency	Critical

5.5 识别规则

双击识别（固件侧）

- 按下 → 释放 = 一次 click
- 两次 click 间隔 $\leq 350\text{ms}$ → 判定 double_click
- 双击成立后发送 eventType = 0x04

长按识别（固件侧）

- 按下持续 $\geq 800\text{ms}$ → 触发 long_press_start (0x05)
- 释放时发送 long_press_end (0x06)

三击识别（v2.0 新增）

- 三次 click，每次间隔 ≤ 350ms → 判定 triple_click
- 用于紧急授权场景

5.6 事件包示例

```
双击（低风险查询）： 02 01 04 07 5A 00
→ 协议 v2 / Button / double_click / seq=7 / 电量 90% / reserved

长按确认（高危操作）： 02 01 05 08 5A 00
→ 协议 v2 / Button / long_press_start / seq=8 / 电量 90% / reserved
```

6. Layer 2：授权凭证层

6.1 Grant 凭证结构

字段	类型	说明
Grant_ID	UUID	单次授权唯一凭证，全局唯一
Device_ID	String	端点唯一 UID（量产版本出厂烧录；原型阶段为软件标识）
Bind_Hash	char[64]	绑定操作者身份 SHA-256 哈希（关联 Layer 0）
Physical_Action	Enum	double_click / long_press / triple_click
Risk_Level	Enum	low / high / critical
Permission_Scope	JSON	本次授权的权限范围（岗位上下文权限包）
Expire_Time	Timestamp	凭证过期时间
Issue_Time	Timestamp	凭证签发时间
Signature	String	端点私钥签名（量产安全版本由 SE 芯片片内完成；原型阶段为软件密钥模拟）
Geo_Context	JSON	按压时地理位置与环境上下文（可选）

6.2 Permission_Scope 示例

低风险查询（双击触发）

```
{
  "target_system": "feishu",
  "context_id": "position_12345",
  "allowed_actions": ["read_docs", "read_meeting_notes", "ai_chat"],
  "denied_actions": ["export", "share_external", "delete"],
  "data_retention": "session_only",
  "max_duration_minutes": 10
}
```

高危操作（长按触发）

```
{
  "target_system": "feishu",
  "context_id": "position_12345",
  "allowed_actions": ["export_docs", "share_external"],
  "denied_actions": ["delete"],
}
```

```
"data_retention": "session_only",
"max_duration_minutes": 5,
"requires_physical_confirm": true,
"physical_action_type": "long_press"
}
```

6.3 风险分级与触发规则

风险等级	触发动作	适用场景	凭证时效	权限范围
Low	双击（0x04）	AI 对话、查询岗位资料、读取会议纪要	10 分钟	只读，不可导出
High	长按（0x05 + 0x06）	批量导出、对外分享、外发文件	5 分钟	限定操作，完成即销毁
Critical	三击（0x07）	紧急授权、管理员特权操作	3 分钟	单次操作，一次性凭证

6.4 Geo_Context 字段（环境感知）

操作者每次按压时，在法务用户协议预设授权范围内可采集以下环境信息，用于场景判别与上下文增强：

```
{
  "gps": "22.5431,114.0579",
  "wifi_ssids": ["CMCC-Office", "Huawei-AP-3F"],
  "bluetooth_devices": ["00:1A:7D:DA:71:13"],
  "inferred_scene": "office",
  "timestamp": "2026-08-01T14:30:00Z"
}
```

用途：自动判别操作者所处场景（办公 / 商场 / 健身 / 驾车 / 居家），结合场景预置策略发起 AI 调用。

【设计意图】Geo_Context 采集依赖控制端 App 的系统权限与用户明示授权，原型阶段未完整实现；采集范围受隐私合规约束，默认不开启。详见第 12 章。

7. Layer 3：审计层

7.1 审计日志结构

字段	说明
Log_ID	日志唯一 ID
Grant_ID	关联的授权凭证 ID
Device_ID	端点设备 ID
User_Bind_Hash	操作者身份哈希
Action_Type	操作类型（查询 / 导出 / 外发 / 删除等）
Risk_Level	风险等级
Physical_Action	物理触发动作

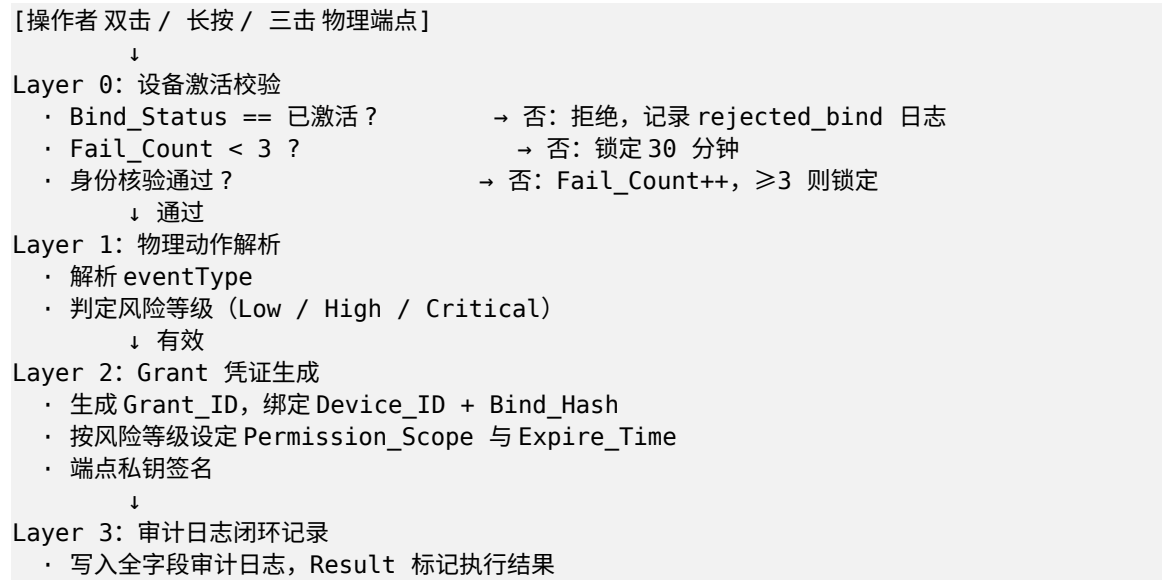
字段	说明
Timestamp	操作时间戳
Result	success / failed / expired / revoked / rejected_bind
Geo_Context	操作时地理位置与环境
Signature_Verified	签名校验结果（true / false）
Revoke_Reason	撤销原因（如挂失 / 熔断 / 管理员操作）

7.2 审计日志存储策略

- 所有日志在企业侧加密存储，默认不上云。
- 支持按时间、设备、操作者、风险等级检索。
- 日志不可篡改（追加写入，链式哈希校验）。
- 保留期限由企业策略配置（默认 180 天）。
- 支持导出用于合规审计报告。

【设计意图】链式哈希防篡改机制为协议设计目标，原型阶段以常规追加写入日志实现，尚未启用链式校验与独立审计接口。详见第 12 章。

8. 凭证生命周期



9. 安全防护机制（五层纵深防御）

第一层：双因素绑定（端点激活防护）

- 物理端点必须绑定操作者生物特征（指纹 / 人脸）或独立 PIN 码才能激活。
- 物理持有 ≠ 权限获得：拾得端点无法使用。
- 连续 3 次核验失败自动锁定 30 分钟。
- 管理员可远程强制解绑、重新绑定。

【设计意图】 本层依赖量产安全版本的安全存储与生物特征核验能力。原型阶段以 PIN 码 / 软件模拟验证流程逻辑。

第二层：企业策略兜底（运营管控）

- 管理员后台支持遗失上报与熔断机制。
- 操作者 App 一键挂失，Bind_Status → 冻结。
- 异常行为自动冻结（如失联后突然在异地发起请求）。
- 冻结后需管理员人工复核解封。

第三层：端点级防拆（物理防护）

- 安全芯片具备物理防拆自毁机制。
- 任何试图拆解读取芯片的行为 → 密钥自动擦除。
- 端点私钥永不出芯片，签名在芯片内部完成。

【设计意图】 防拆自毁与片内签名为量产安全版本的设计目标，原型阶段端点未集成 SE 安全芯片，签名由软件密钥模拟，不具备物理防拆能力。严禁将本层表述为已实现能力。

第四层：凭证级安全（协议防护）

- 每次授权生成独立 Grant_ID，不可复用。
- 端点私钥签名，防伪造。
- 限时过期（3-10 分钟），结合 nonce 与时间戳防重放。
- 权限最小化（Permission_Scope 精确到操作级别）。
- 全链路审计留痕，可追溯。

第五层：数据级安全（隐私防护）

- 敏感数据本地处理，默认不上云。
- 会话级数据留存，凭证销毁即清除。
- 涉及个人隐私信息留存本地，不上传云端。
- Geo_Context 采集受用户明示授权与隐私合规约束。

10. 端点遗失应急流程

```

[端点丢失 / 被盗]
    ↓
[操作者 App 一键挂失] 或 [后台异常行为自动冻结]
    ↓
Bind_Status → 0x02（已冻结）
    ↓
该 Device_ID 所有未过期 Grant 凭证强制撤销
    ↓
即使拾得端点：
    · Layer 0 拦截：未通过身份核验，无法生成新凭证
    · Layer 2 拦截：旧凭证已被撤销，企业侧拒绝
    · Layer 3 记录：所有尝试均写入审计日志
    ↓
[管理员人工核验 → 确认安全]
  
```

↓

[旧端点解绑 → 签发新端点 → 重新绑定]

岗位上下文容器权限迁移，数据不动

核心结论：端点遗失不等于数据泄露。它只是触发了企业安全事件响应流程中一道明确的“人工核验”环节，反而让原本模糊的安全事件有了可操作、可归因、可追溯的切入点。

11. 岗位上下文交接协议

步骤	操作	涉及层
1	管理员后台回收离职人员物理端点	Layer 0：Bind_Status → 0x00
2	岗位上下文容器权限标记为“待分配”	Layer 2：Permission_Scope 挂起
3	签发新端点给继任人员	Layer 0：新端点绑定
4	新人员 App 端岗位 Tab 自动切换	应用层：上下文容器权限迁移
5	离职人员审计日志永久留存	Layer 3：不可篡改

关键原则：上下文数据不随硬件流转，物理端点只是身份凭证。数据始终存储在企业侧加密容器中，端点的作用是“确权”——证明当前操作者有权访问该岗位的上下文。

12. 实现状态声明

本章是本规范的重要组成部分。为避免将设计意图误述为已实现能力，下表对所有关键能力逐项标注实现状态。任何对外材料、安全评审与客户沟通，均应以本章为准。

能力项	状态	说明
BLE 6 字节事件包协议	已实现（原型）	端点固件已实现事件包封装与 Notify 上报。
双击 / 长按 / 三击识别	已实现（原型）	固件侧时序识别逻辑已完成，阈值 350ms / 800ms。
Grant 凭证结构与字段定义	已实现（原型）	凭证由控制端软件生成与校验，字段结构如第 6.1 节。
风险分级与时效策略	已实现（原型）	Low / High / Critical 三档映射与 10 / 5 / 3 分钟时效已在原型中实现。
审计日志结构与写入	已实现（原型）	常规追加写入日志已实现，字段如第 7.1 节。
端点绑定流程（PIN）	已实现（原型）	以 PIN 码方式验证绑定与冻结流程逻辑。
岗位上下文交接流程	已实现（原型）	应用层权限迁移与日志留存已完成。
验收标准 L1 / L2	已实现（原型）	事件到达与触发反馈已通过原型验收。
Layer 0 生物特征绑定	设计意图	依赖量产安全版本的指纹 / 人脸核验与安全存储，原型未实现。

能力项	状态	说明
SE 芯片片内签名	设计意图	量产版本由安全芯片在片内完成签名；原型阶段为软件密钥模拟。
私钥永不出芯片	设计意图	同上，依赖安全芯片硬件隔离，原型不具备此属性。
物理防拆自毁	设计意图	量产安全版本的物理防护目标，原型端点未集成相关硬件。
链式哈希防篡改审计	设计意图	审计日志的链式校验与独立审计接口尚未启用。
Geo_Context 环境感知采集	设计意图	依赖控制端系统权限与用户明示授权，默认关闭。
跨生态 A2A 接入	未来工作	依赖第三方 Agent 平台采纳本规范。
真实支付 / 生产系统接口	未来工作	需与支付机构、ITSM / 运维系统对接。
第三方安全审计与渗透测试	未来工作	尚未开展。
大规模组织部署验证	未来工作	尚无外部客户 POC、付费或生产部署。

【声明原则】 本规范将“规范目标状态”与“当前实现范围”严格分离：第 4–11 章描述目标状态，本章描述当前实现范围。原型证明执行力，不等于商业验证；设计意图不等于已实现能力。

13. 验收标准（三层）

层级	验收内容	成败判定
L1：事件到达	操作者双击端点 → 控制端服务收到 BLE 事件	必须成功
L2：触发反馈	收到事件后 → 手机震动 / 通知 / 状态栏提示	必须成功
L3：直接拉起	收到事件后 → 直接打开 AI Ready 界面	增强项，不作为唯一成败判定

14. 安全考量（Security Considerations）

14.1 威胁模型

- T1 端点遗失 / 被盗：由 Layer 0 绑定 + Layer 2 凭证撤销 + Layer 3 审计共同缓解（见第 10 章）。
- T2 重放攻击：由 nonce + 时间戳 + 服务端去重窗口缓解；量产版本增强为 PoP 设备密钥绑定。
- T3 提示注入诱导授权：物理按压提供独立于 Agent 信任域的确认信道，但无法防御对操作者本人的社工攻击。
- T4 凭证泄露：限时（3–10 分钟）+ 单次消费 + 权限最小化三重约束降低泄露影响面。
- T5 侧信道与物理拆解：仅由量产安全版本的防拆机制缓解，原型不具备此能力。

14.2 残余风险

本规范不声称“不可伪造”“不可重放”“绝对安全”。在原型阶段，端点私钥以软件形式存在，其安全边界等同于承载它的通用计算设备。所有超出当前实现范围的安全声明，必须以第 12 章的实现状态为准。

15. 版本历史

版本	日期	主要变更
v1.0	2026-07	初始版本：Grant 凭证结构、风险分级、审计日志、BLE 事件包协议。
v2.0	2026-08	新增 Layer 0 双因素绑定层（端点激活防护）；新增三击紧急事件（0x07）；新增端点遗失应急流程；新增五层纵深防御体系；新增岗位上下文交接协议；新增 Geo_Context 环境感知字段；新增凭证生成前置校验；protocolVersion 升级为 0x02。
v2.0（中立化）	2026-09-06	删除全部厂商与产品品牌标识，术语中立化；新增第 2 章“与现有标准的关系”、第 12 章“实现状态声明”、第 14 章“安全考量”；面向社区评议与产业采用发布。

附录 A：术语中立化对照表

本附录仅供协议设计方内部对照使用，不属于规范正文。中立化目的是使本规范可被任意厂商、任意形态端点（按键 / 戒指 / 手环 / 手表 / 眼镜）实现，而不绑定特定产品或品牌。

内部代号（非规范）	规范术语（中立化）	说明
一闪	协议设计方 / Specification Author	厂商或项目品牌名，规范中不出现。
RoleKey	物理授权端点（Physical Authorization Endpoint, PAE）	承载物理确认动作的硬件端点，形态不限。
Yishan_Button_01	IG-Button-01	端点广播名的参考命名示例，非绑定值。
硬件 / 戒指	端点 / Endpoint	形态无关表述，可为按键、戒指、手环、手表、眼镜等。
员工	操作者 / Operator	与岗位绑定的授权主体。
企业后台 / 管理员	控制平面 / Control Plane	策略下发与生命周期管理的逻辑实体。
App	控制端应用 / Controller	运行在通用计算设备上、与端点配对的控制软件。

— 规范结束 —

本规范文本与参考实现拟以 Apache License 2.0 发布。协议设计方：苏亚伟（Su Yawei）。